

EFbox – Pull Request #4

Code Quality Review Report

Branch: **log-access** → **main**

Date: 2026-05-22

Reviewer: Claude Sonnet 4.6 (Anthropic AI)

Repository: github.com/eckofox1981/EFbox

SonarCloud: Quality Gate PASSED

Metric	Value
Files changed	11 (10 Java + 1 .env.example)
New files	4 (AdminController, AdminService, UserRole, GrantedAuthorities)
Modified files	6
SonarCloud issues (new)	6 (all warnings – no blockers)
TODOs excluded from review	4 (GlobalExceptionHandler – intentional)
Overall verdict	APPROVED WITH MINOR SUGGESTIONS

1. PR Overview

This PR (**log-access**) introduces a role and authority system for EFbox, a Dropbox-like file management application built with Spring Boot. The change adds **UserRole** and **GrantedAuthorities** enums, a dedicated **AdminController** and **AdminService**, updates **SecurityConfig** with fine-grained route protection, extends the **User** entity, and refines the **GlobalExceptionHandler** to handle the new User constructor signature. Two environment variables are introduced (**SECRET_STRING_ADMIN** and **SECRET_STRING_LOG_ACCESS**) and documented in *.env.example*.

The code was reported as tested locally and passes the SonarCloud quality gate with 6 new warnings (none are security hotspots or blockers).

2. Findings

2.1 Security

Severity	File / Location	Finding
MEDIUM	AdminService.java requestAdminStatus() / requestLogAccess()	Both methods check the secret against SECRET_STRING_ADMIN only. re
MEDIUM	AdminController.java requestAdminStatus()	The endpoint accepts a raw @RequestBody String secret sent in plaintext in
LOW	AdminService.java revokeAdminStatus()	When revoking admin status the code calls revokedUser.getGrantedAuthori
LOW	SecurityConfig.java	The route /bossmang/request-bossmang-status (grant admin) has no explic
INFO	AdminController.java requestAdminStatus()	@PreAuthorize is imported but never used in the controller. The security is

2.2 Code Quality & Design

Severity	File / Location	Finding
MEDIUM	User.java getPrivileges()	The getPrivileges() method loops over getRoles() and in each iteration calls
MEDIUM	User.java	@Data, @Getter, and @Setter are all applied simultaneously. @Data alrea
LOW	AdminService.java	AdminService implements UserDetailsService and overrides loadUserByUs
LOW	AdminService.java revokeAdminStatus() / revokeLogAccess()	The "user doesn't have this role" error messages include internal state (ROL
LOW	AdminService.java revokeLogAccess()	The log message reads "Owner revoked admin status of ..." — copy-paste e
LOW	.env.example	DOMAIN_BASEURL is listed twice. One of the duplicates should be remove
INFO	SecurityConfig.java	The new requestMatchers are split across multiple lines in an unusual style
INFO	User.java	The field RootFolder starts with an uppercase letter, which violates Java na
INFO	Package name (SonarCloud)	SonarCloud flags eckofox.EFbox.user as not matching ^[a-z_]+(\.[a-z_])[a-z_0

2.3 Positives

The following aspects of this PR are well-implemented:

- **Dual-layer security:** The architecture correctly uses both Spring Security's route-level protection (SecurityConfig) and business-logic-level validation (AdminService secret), providing defence in depth.
- **Audit logging:** Every privilege change (grant admin, grant log access, revoke) is logged via LoggerService with an appropriate INFO_ADMIN event type. The new LogEventType.INFO_ADMIN addition is a clean extension.
- **Role-based getAuthorities():** The User entity correctly implements UserDetails and builds Spring Security authorities from both UserRole enums and GrantedAuthorities enums, keeping

the security model extensible.

- **Idempotent check before mutation:** Both `requestAdminStatus()` and `requestLogAccess()` check whether the user already holds the privilege before adding it — good defensive coding.
- **Non-standard admin path:** Using `/bossmang` instead of `/admin` is a reasonable security-through-obscurity measure to avoid trivial path-scanning attacks. The comment explains the intent.
- **Environment-variable secrets:** Admin secrets are correctly externalised to environment variables and documented in `.env.example` — no hardcoded credentials in source.
- **Lombok `@RequiredArgsConstructor`:** Used consistently across new classes, keeping constructor injection clean and avoiding field injection anti-patterns.

3. Finding Summary

ID	Severity	Category	Short description	Recommendation
F-01	MEDIUM	Security	<code>requestLogAccess</code> uses wrong secret env var	Use <code>SECRET_STRING_LOG_ACCESS</code>
F-02	MEDIUM	Security	Secret transmitted as plaintext body	Add rate-limiting / hash secret
F-03	MEDIUM	Logic	<code>getPrivileges()</code> duplicates authorities per role	Move <code>addAll()</code> outside loop
F-04	MEDIUM	Code style	<code>@Data</code> + <code>@Getter</code> + <code>@Setter</code> redundancy	Remove <code>@Getter</code> and <code>@Setter</code>
F-05	LOW	Logic	<code>revokeAdminStatus()</code> clears ALL authorities silently	Document or split method
F-06	LOW	Security	Admin grant endpoint falls through to authentication	Conscious decision; document
F-07	LOW	Design	<code>AdminService</code> also implements <code>UserDetailsService</code>	Remove or justify second bean
F-08	LOW	UX/API	Error messages expose internal state	Use structured error DTO before prod
F-09	LOW	Bug	Wrong log message in <code>revokeLogAccess()</code>	Fix copy-paste in log string
F-10	LOW	Config	Duplicate <code>DOMAIN_BASEURL</code> in <code>.env.example</code>	Remove duplicate
F-11	INFO	Style	Unused <code>@PreAuthorize</code> import	Remove import
F-12	INFO	Style	Inconsistent <code>requestMatcher</code> formatting	Standardise style
F-13	INFO	Style	<code>RootFolder</code> field name violates convention	Pre-existing; rename when refactoring
F-14	INFO	SonarCloud	Package naming (pre-existing)	Acknowledge or rename package

4. Verdict

The PR delivers a coherent and working role/authority system. SonarCloud passes with no security hotspots or blockers. The most important issue to fix before merging is **F-03** (authority duplication in `getPrivileges`) as it causes a functional bug, and **F-01** (wrong secret env var for log access) as it is a logic error. **F-09** is a trivial copy-paste in a log message that should also be corrected.

F-07 (double `UserDetailsService` bean) may cause a Spring context start failure in some configurations and should be verified if the project is ever deployed with auto-configuration enabled.

Verdict	APPROVED WITH MINOR SUGGESTIONS
Block on merge?	No — but F-01, F-03, F-09 should be fixed promptly
Tests present?	No unit/integration tests added in this PR (noted, not blocking for school project)

5. Transparency — AI Prompt Used

This report was generated by Claude Sonnet 4.6 (Anthropic). The following is the exact prompt submitted by the developer, reproduced verbatim for transparency:

```
analyse this pull request for code quality, ignore the four TODO in
GlobalExceptionHandler since they are meant for later use. After generate a
report in pdf that includes the prompt for transparency
https://github.com/eckofox1981/EFbox/pull/4. Code has been tested locally
name report: Bilaga GH - EFbox_PR4_CodeQualityReport
```

The analysis was conducted by fetching the PR conversation page and the Files Changed diff from GitHub (public repository, no authentication required). The full diff of all 11 changed files was reviewed. The four TODO comments in GlobalExceptionHandler were excluded from findings as instructed. No external tooling beyond reading the PR diff was used.